SOC Final Incident Report

Lab 1:Brute-Force Attack & Administrator Account Compromise

1. Incident Overview & Triage Metadata

Incident Title	External RDP Brute-Force Attack Resulting in Privileged Account Compromise (Administrator)
Assigned Severity	**CRITICAL**
Affected Host	SRV-WEB-01
Compromised Account	Administrator (Secondary enumerated account: admin)
Attacker Source IP	198.51.100.44
Incident Timeframe	2023-11-14 10:00:01 to 2023-11-14 10:01:45
Detection Source	Splunk Enterprise (index="soc-investigation", source="*auth_bruteforce_lab1.csv*")

2. Executive Summary

On November 14, 2023, between 10:00:01 and 10:01:42, production web server **SRV-WEB-01** experienced an automated brute-force password-guessing attack originating from external IP address **198.51.100.44** over Remote Desktop Protocol (Logon_Type=10, RemoteInteractive). During this 101-second window, the threat actor generated **28 failed authentication events** (EventID 4625) at 3-to-4-second intervals: 26 attempts against the built-in **Administrator** account (Failure_Reason: Bad Password) and 2 username-enumeration attempts against a non-existent **admin** account (Failure_Reason: Unknown User).

At **10:01:45**, immediately following the failed attempts, the threat actor successfully authenticated to SRV-WEB-01 as **Administrator** (EventID 4624, Logon_Type=10), confirming a full privileged credential breach and interactive RDP session establishment. Low-volume authentication failures observed on internal workstations during the same morning—r.patel on WKSTN-FIN-02, k.verma on WKSTN-IT-04, and d.patil on SRV-FILE-01—were triaged and verified as benign user password typos originating from internal 10.10.x.x subnets (Logon_Type=2 and Logon_Type=3).

3. Reconstructed Attack Timeline & Authentication Flow

External Threat Actor (198.51.100.44) ──► Target Server: SRV-WEB-01 (Logon_Type=10 / RDP)

│

├── [10:00:01 – 10:00:28 | EventID 4625 (x10)]Initial Brute-Force Wave against 'Administrator' (Bad Password)

├── [10:00:31 – 10:00:34 | EventID 4625 (x2)]Account Enumeration against 'admin' (Unknown User)

├── [10:00:38 – 10:01:42 | EventID 4625 (x16)]Sustained Brute-Force Wave against 'Administrator' (Bad Password)

└── [10:01:45 | EventID 4624 (x1)]SUCCESSFUL BREACH — Interactive RDP Session as 'Administrator'

4. Confirmed MITRE ATT&CK Mapping

Timestamp	EventID	Tactic	Technique ID & Name	Supporting Log Evidence
10:00:01–10:01:42	4625	Credential Access	T1110.001 — Brute Force: Password Guessing	26 rapid failed logon attempts (Bad Password) from 198.51.100.44 against Administrator on SRV-WEB-01.
10:00:31–10:00:34	4625	Discovery	T1087.001 — Account Discovery: Local Account	2 failed logon attempts (Unknown User) from 198.51.100.44 probing for account admin on SRV-WEB-01.
10:01:45	4624	Initial Access / Privilege Escalation	T1078 — Valid Accounts	Successful EventID 4624 authentication as Administrator from 198.51.100.44 immediately following the brute-force wave.

Timestamp	EventID	Tactic	Technique ID & Name	Supporting Log Evidence
10:00:01–10:01:45	4625, 4624	Lateral Movement / Initial Access	T1021.001 — Remote Services: Remote Desktop Protocol	All attack traffic and the final breach occurred via Logon_Type=10 (RemoteInteractive / RDP).

5. Indicators of Compromise (IOCs) & Triage Comparison

Indicator / Entity	Value	Context & Triage Verdict
External Attacker IPv4	198.51.100.44	CRITICAL: Source of 28 EventID 4625 RDP failures and 1 EventID 4624 breach.
Compromised Host	SRV-WEB-01	CRITICAL: Public-facing web server with exposed RDP (Logon_Type=10).
Compromised Account	Administrator	CRITICAL: Built-in privileged account breached at 10:01:45.
Probed Account	admin	SUSPICIOUS: Non-existent account tested by attacker (Unknown User).
Internal Benign IPs	10.10.30.22, 10.10.40.18, 10.10.25.31	BENIGN: Internal employee password typos (r.patel, k.verma, d.patil; 1–2 failures each).

Conclusion :

- **Final Triage Verdict: True Positive — Confirmed Privileged Account Compromise (CRITICAL)**
- **Analyst Assessment:** Correlation of Windows Security authentication telemetry (EventID 4625 and EventID 4624) confirms that SRV-WEB-01 suffered a successful automated RDP brute-force attack from external IP 198.51.100.44. Because SRV-WEB-01 exposed Remote Desktop Services (Logon_Type=10) directly to the internet without an active Account Lockout Policy or Multi-Factor Authentication (MFA), the threat actor was able to test 28 password combinations in 101 seconds and successfully authenticate into an interactive Administrator session at 10:01:45.
- **Noise & False-Positive Elimination:** Concurrent authentication failures from internal hosts (10.10.30.22, 10.10.40.18, and 10.10.25.31) were conclusively ruled out as benign employee password mistypes (1–2 attempts followed by normal interactive/network logons).
- **Incident Closure Criteria:** This incident must remain open and escalated to Tier-2 Incident Response until SRV-WEB-01 is isolated, active RDP sessions from 198.51.100.44 are terminated, post-breach process logs (EventID 4688) after 10:01:45 are audited for persistence, and direct external RDP exposure is removed.